



Curso: Gestión de Riesgos de la Ciberseguridad

Freddy Alvarado Vargas

Profesor Área Operaciones y Tecnologías de la Información
Gerente de Operaciones y TI en empresas del sector
industrial, retail y telecomunicaciones.



1

Curso: Gestión de Riesgos de la Ciberseguridad

Sesión 4

Monitoreo, Mejora Continua y Gestión Aplicada

Freddy Alvarado Vargas
falvarado@esan.edu.pe



2



Sesión 3: EVALUACIÓN Y TRATAMIENTO DE RIESGOS

1. Logro de aprendizaje de la sesión

Al finalizar la sesión, el participante será capaz de monitorear riesgos de ciberseguridad mediante indicadores clave de riesgo (KRI), gestionar incidentes, realizar seguimiento continuo de controles, aplicar procesos de auditoría y mejora continua, e identificar riesgos emergentes asociados a la transformación digital, la computación en la nube, la inteligencia artificial y el Internet de las Cosas (IoT).



Freddy Alvarado Vargas
falvarado@esan.edu.pe



3



1. Introducción

La gestión de riesgos no culmina con la implementación de controles. Los riesgos evolucionan constantemente debido a nuevas amenazas, cambios tecnológicos, vulnerabilidades emergentes y transformaciones en el entorno organizacional.

Por ello, las organizaciones deben implementar mecanismos permanentes de:

- Monitoreo.
- Medición.
- Auditoría.
- Gestión de incidentes.
- Mejora continua.

El objetivo es garantizar que los riesgos permanezcan dentro de niveles aceptables y que los controles continúen siendo efectivos.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



4

2. Indicadores Clave de Riesgo (KRI)

¿Qué es un KRI?

Un Key Risk Indicator (KRI) es una métrica que permite monitorear la evolución de un riesgo y alertar oportunamente sobre posibles desviaciones.

Los KRIs ayudan a responder preguntas como:

- ¿Está aumentando el riesgo?
- ¿Los controles están funcionando?
- ¿Existen señales tempranas de un incidente?

Características de un buen KRI

- Medible.
- Relevante.
- Oportuno.
- Predictivo.
- Fácil de interpretar.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



5

2. Indicadores Clave de Riesgo (KRI)

Ejemplos de KRIs de Ciberseguridad

Riesgo	Indicador (KRI)	Umbral
Ransomware	% de equipos sin parches críticos	>10%
Phishing	Número de usuarios que hacen clic en correos simulados	>15%
Fuga de datos	Cantidad de transferencias no autorizadas	>20 eventos
Accesos indebidos	Intentos fallidos de autenticación	>500 por día
Vulnerabilidades	Vulnerabilidades críticas abiertas	>30 días



Ejemplo práctico

Entidad pública:

Objetivo: Reducir ataques de phishing.

KRI:

Porcentaje de funcionarios que hacen clic en simulaciones de phishing.

Resultado actual: **20%**

Meta: **Menor a 5%**

Interpretación:

Existe una alta exposición al riesgo y se requiere capacitación adicional.

Freddy Alvarado Vargas
falvarado@esan.edu.pe



6

INDICADORES CLAVE DE RIESGO (KRI)

¿QUÉ ES UN KRI?
 Un Key Risk Indicator (KRI) es una métrica que permite monitorear la evolución de un riesgo y anticipar posibles eventos o incidentes.

Miden la exposición al riesgo y alertan de forma temprana para tomar acciones oportunas.

CARACTERÍSTICAS DE UN BUEN KRI

Medible
 Cuantificable con datos confiables.

Relevante
 Relacionado con riesgos críticos.

Oportuno
 Disponible en tiempo y con frecuencia adecuada.

Predictivo
 Anticipa cambios o eventos antes de que ocurran.

Fácil de interpretar
 Comprensible para la toma de decisiones estratégicas.

¿PARA QUÉ SIRVEN?

- Detectar señales tempranas de aumento del riesgo.
- Evaluar la efectividad de los controles.
- Priorizar acciones y asignar recursos.
- Reducir la probabilidad e impacto de incidentes.

EJEMPLOS DE KRI POR TIPO DE INDUSTRIA O SECTOR ECONÓMICO

TIPO DE RIESGO	FINANCIERO	SALUD	GOBIERNO / SECTOR PÚBLICO	MANUFACTURA	COMERCIO / RETAIL	EDUCACIÓN	ENERGÍA Y SERVICIOS PÚBLICOS
Amenazas y Exposición	• Intentos de phishing exitosos (sitios que fueron clic) • Número de amenazas detectadas por endpoint	• Correo malicioso bloqueado • Intentos de ransomware detectados	• Intentos de intrusión en portales y servicios en línea • Actividad de amenazas persistentes (APT)	• Intentos detectados en sistemas OT/ICS • Escaneo o acceso no autorizado a redes OT	• Intentos de fraude en transacciones en línea • Ataques a aplicaciones web detectados	• Sitios maliciosos bloqueados • Intentos de phishing reportados	• Alertas de amenazas en redes industriales (OT) • Actividad anómala detectada en sistemas de control
Vulnerabilidades y Exposición	• % de vulnerabilidades críticas abiertas > 30 días • Vulnerabilidades críticas sin parches	• % de dispositivos médicos sin parches • Vulnerabilidades críticas sin parches	• % de activos críticos con vulnerabilidades abiertas • Sistemas sin actualización de seguridad	• Dispositivos OT con vulnerabilidades críticas • Software/firmware desactualizado	• % de aplicaciones sin parches críticos • Vulnerabilidades críticas en e-commerce	• Equipos sin parches de seguridad • Software educativo desactualizado	• % de sistemas SCADA sin parches críticos • Vulnerabilidades en infraestructura crítica
Accesos e Identidades	• Intentos fallidos de inicio de sesión (por día) • Cuentas privilegiadas activas sin uso > 30 días	• Usuarios con accesos excesivos • Cuentas sin MFA habilitada	• Accesos privilegiados fuera de horario laboral • Cuentas compartidas detectadas	• Accesos remotos sin MFA a sistemas críticos • Cambios no autorizados en configuraciones OT	• Cuentas de administradores sin MFA • Accesos sospechosos desde ubicaciones inusuales	• Estudiantes con privilegios elevados • Accesos desde dispositivos no gestionados	• Accesos remotos sin autorización estricta • Cuentas sin revisión periódica
Incidentes y Respuesta	• Número de incidentes de seguridad (mensual) • Tiempo promedio de detección (MTTD)	• Incidentes reportados a incidentes (MTTR) • Tiempo de respuesta a incidentes (MTTR)	• Incidentes de seguridad en servicios digitales • Tiempo de recuperación de servicios críticos	• Paradas no planificadas por incidentes cibernéticos • Tiempo de recuperación de sistemas OT	• Incidentes que afectan ventas en línea • Tiempo de recuperación de plataformas	• Incidentes que afectan plataformas educativas • Tiempo de recuperación de incidentes	• Incidentes que impactan la operación • Tiempo de recuperación del servicio
Concientización y Personas	• % de usuarios que hacen clic en simulaciones de phishing • % de capacitación completada	• % de personal capacitado en ciberseguridad • Click rate en simulaciones de phishing	• Reportes de phishing por usuarios • Reportes de incidentes de seguridad	• Reportes de incidentes en seguridad OT/IT • Reportes de incidentes por empleados	• % de empleados capacitados en seguridad • Participación en campañas de concientización	• % de docentes y personal capacitado • Participación de estudiantes en campañas	• % de personal entrenado en seguridad industrial • Cultura de reporte de incidentes
Protección de Datos	• Transferencias de datos no autorizadas • Eventos de pérdida de datos (DLP)	• Accesos no autorizados a historial clínico • Intentos de exfiltración de datos	• Filtros de información pública o sensible • Descargas masivas de datos por usuarios	• Intentos de copia de información a dispositivos externos • Exfiltración de datos de propiedad intelectual	• Exposición de datos de clientes • Incidentes de fraude con datos personales	• Accesos indebidos a datos de estudiantes • Exposición de información académica o personal	• Accesos no autorizados a datos operativos • Exposición de información crítica

BUENAS PRÁCTICAS

- Seleccionar KRIs relevantes a los riesgos críticos del negocio.
- Definir umbrales y acciones de respuesta claras.
- Revisar y ajustar los KRIs periódicamente.
- Usar dashboards para una visualización efectiva.

DE LOS DATOS A LA ACCIÓN
Datos y métricas (KRI)

Análisis y monitoreo

Detección de señales tempranas

Decisiones y acciones preventivas

Reducción del riesgo y mayor resiliencia

Los KRIs no eliminan el riesgo, pero permiten gestionarlo de manera proactiva, oportuna y efectiva.

7

3. Monitoreo Continuo

Definición

Proceso permanente de supervisión de riesgos, amenazas, vulnerabilidades y controles.

Permite detectar:

- Actividades sospechosas.
- Incidentes.
- Cambios en el entorno.
- Desviaciones de los indicadores



8

3. Monitoreo Continuo

Componentes

Monitoreo de activos

- Servidores.
- Redes.
- Aplicaciones.

Monitoreo de vulnerabilidades

- Escaneos periódicos.
- Gestión de parches.

Monitoreo de amenazas

- Inteligencia de amenazas.
- Indicadores de compromiso (IoC).

Monitoreo de usuarios

- Accesos.
- Privilegios.
- Comportamientos anómalos.



Herramientas comunes

- SIEM.
- SOAR.
- EDR/XDR.
- Vulnerability Scanners.

Dashboards de KRIs.

Freddy Alvarado Vargas
falvarado@esan.edu.pe





4. Auditoría de Seguridad

Definición

Proceso sistemático para verificar el cumplimiento de políticas, estándares y controles de seguridad

Objetivos

- Verificar cumplimiento.
- Identificar brechas.
- Evaluar efectividad de controles.
- Detectar oportunidades de mejora.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



11



4. Auditoría de Seguridad

Tipos de auditoría

Interna

Realizada por la propia organización.

Externa

Realizada por terceros independientes.

Regulatoria

Realizada por organismos supervisores.



Ejemplos

Sector financiero

Auditoría de cumplimiento ISO/IEC 27001.

Sector público

Evaluación de cumplimiento de políticas de Gobierno Digital.

Universidad

Auditoría de accesos privilegiados.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



12

Principales empresas certificadoras y organismos de evaluación en Seguridad de la Información en el Perú

Las certificaciones ISO/IEC 27001 son emitidas por organismos certificadores acreditados internacionalmente. En Perú, diversas empresas operan directamente o mediante representantes regionales para realizar auditorías y certificaciones de Sistemas de Gestión de Seguridad de la Información (SGSI).

Empresa Certificadora	País de origen	Certificaciones relacionadas	Presencia en Perú	Sectores atendidos
BSI Group	Reino Unido	ISO/IEC 27001, ISO 22301, ISO 9001, ISO 31000	Sí	Financiero, telecomunicaciones, gobierno, educación
DNV	Noruega	ISO/IEC 27001, ISO 22301, ISO 9001	Sí	Energía, industria, minería, servicios
Bureau Veritas	Francia	ISO/IEC 27001, ISO 22301, ISO 20000-1	Sí	Gobierno, banca, retail, industria
SGS	Suiza	ISO/IEC 27001, ISO 22301, ISO 9001	Sí	Industria, minería, sector público
TÜV Rheinland	Alemania	ISO/IEC 27001, ISO 20000-1, ISO 22301	Sí	Manufactura, telecomunicaciones, TI
TÜV SÜD	Alemania	ISO/IEC 27001, ISO 9001, ISO 22301	Sí	Energía, industria, servicios
LRQA	Reino Unido	ISO/IEC 27001, ISO 22301, ISO 9001	Sí	Logística, transporte, tecnología
AENOR	España	ISO/IEC 27001, ENS, ISO 22301	Sí	Gobierno, banca, educación
ICONTEC	Colombia	ISO/IEC 27001, ISO 22301, ISO 9001	Sí	Sector público y privado
Intertek	Reino Unido	ISO/IEC 27001, ISO 22301	Sí	Tecnología, manufactura, servicios

5. Gestión de Incidentes

Definición

Proceso para identificar, responder, contener y recuperar operaciones después de un incidente de seguridad.

Objetivos

- Reducir impactos.
- Restablecer operaciones.
- Preservar evidencia.
- Evitar recurrencias.



5. Gestión de Incidentes

Ciclo de Gestión de Incidentes

1. Preparación

- Políticas.
- Procedimientos.
- Equipos de respuesta.

2. Detección y análisis

- SIEM.
- Alertas.
- Monitoreo.

3. Contención

- Aislamiento de sistemas.
- Bloqueo de accesos.

4. Erradicación

- Eliminación de malware.
- Corrección de vulnerabilidades.

5. Recuperación

- Restauración de servicios.
- Validación operativa.

6. Lecciones aprendidas

- Análisis post-incidente.
- Mejoras de controles.



5. Gestión de Incidentes

Ciclo de Gestión de Incidentes

Ejemplo

Incidente:

Ransomware en una entidad pública.

Acciones:

- Aislamiento de servidores.
- Activación del CSIRT.
- Restauración desde backups.
- Investigación forense.
- Actualización de controles.



6. Mejora Continua (Ciclo PDCA)

ISO/IEC 27001 adopta el modelo de mejora continua de Deming.

Ciclo PDCA

Plan (Planificar)

- Identificar riesgos.
- Diseñar controles.
- Definir KRIs.

Do (Hacer)

- Implementar controles.
- Ejecutar procedimientos.

Check (Verificar)

- Monitorear indicadores.
- Realizar auditorías.

Act (Actuar)

- Corregir desviaciones.
- Mejorar procesos.



Ejemplo

Problema:

Aumento de ataques phishing.

Plan:

Capacitación.

Do:

Implementación del programa.

Check:

Medición del KRI.

Act:

Nuevas campañas de concientización.

CICLO DE MEJORA CONTINUA PDCA

ISO/IEC 27001 adopta el modelo de mejora continua de Deming



19

7. Riesgos en la Transformación Digital

La transformación digital genera nuevas oportunidades, pero también nuevos riesgos.

7.1 Riesgos en Cloud Computing

Amenazas

- Configuraciones incorrectas.
- Accesos no autorizados.
- Dependencia del proveedor.

Ejemplo

Base de datos expuesta públicamente en AWS.



20

7. Riesgos en la Transformación Digital

7.2 Riesgos en Inteligencia Artificial

Amenazas

- Sesgos algorítmicos.
- Manipulación de modelos.
- Deepfakes.
- Filtración de datos.

Ejemplo

Uso de IA generativa para fraude corporativo mediante suplantación de identidad.



7. Riesgos en la Transformación Digital

7.3 Riesgos en IoT

Amenazas

- Dispositivos vulnerables.
- Falta de actualizaciones.
- Acceso remoto no autorizado.

Ejemplo

Ataque a cámaras IP utilizadas en infraestructura crítica.



RIESGOS EN LA TRANSFORMACIÓN DIGITAL

La adopción de tecnologías digitales impulsa la innovación y la eficiencia, pero también introduce nuevos riesgos que deben identificarse, evaluarse y gestionarse de forma proactiva.

1. RIESGOS EN CLOUD COMPUTING

La nube ofrece escalabilidad y flexibilidad, pero transfiere parte del control a terceros (proveedores de nube).

Riesgos principales

- Configuraciones incorrectas que exponen información.
- Accesos no autorizados por gestión inadecuada de identidades.
- Dependencia del proveedor (disponibilidad y continuidad del servicio).
- Fuga de datos o pérdida de información.

Ejemplos

Una base de datos S3 en AWS quedó públicamente expuesta por una configuración incorrecta, permitiendo el acceso y descarga de información confidencial.

2. RIESGOS EN INTELIGENCIA ARTIFICIAL (IA)

La IA mejora procesos y toma de decisiones, pero puede generar riesgos éticos, operativos y de seguridad.

Riesgos principales

- Sesgos algorítmicos que generan decisiones injustas o incorrectas.
- Manipulación de modelos (data poisoning, evasión).
- Deepfakes y generación de contenido falso.
- Filtración de datos usados para entrenar modelos.

Ejemplos

Un atacante usa IA generativa para crear un deepfake de un ejecutivo y engañar a un empleado, logrando una transferencia fraudulenta.

3. RIESGOS EN IoT (INTERNET DE LAS COSAS)

Los dispositivos IoT amplían la conectividad, pero muchos de ellos tienen controles de seguridad limitados.

Riesgos principales

- Dispositivos con firmware vulnerable o sin parches.
- Credenciales débiles o predeterminadas.
- Tráfico no cifrado que puede ser interceptado.
- Uso de IoT como puerta de entrada a la red.

Ejemplos

Cámaras IP con contraseñas por defecto fueron comprometidas y usadas en ataques DDoS masivos contra servicios en Internet.

4. OTROS RIESGOS EMERGENTES

Nuevas tecnologías y modelos de negocio digitales generan riesgos que evolucionan constantemente.

Riesgos principales

- Riesgo en terceros y cadenas de suministro digitales.
- Ciberataques más sofisticados (ransomware, APT, phishing avanzado).
- Privacidad y protección de datos personales.
- Cumplimiento normativo y regulatorio.
- Interrupción de servicios críticos y continuidad del negocio.

Ejemplos

Un proveedor de software es comprometido y el malware se distribuye a múltiples clientes a través de una actualización legítima.

Y MÁS...

Aplicaciones móviles: fugas de datos, permisos excesivos y vulnerabilidades.

Big Data y analítica: exposición de grandes volúmenes de datos sensibles.

Trabajo remoto e híbrido: mayor superficie de ataque y riesgos de acceso.

APIs: exposición insegura, abusos y accesos no autorizados.

¿POR QUÉ ES IMPORTANTE GESTIONAR ESTOS RIESGOS?

- Protege la información crítica y la privacidad de los usuarios.
- Reduce el impacto financiero, operativo y reputacional.
- Asegura el cumplimiento legal y regulatorio.
- Fortalece la resiliencia y la continuidad del negocio.

La transformación digital es una oportunidad. La gestión de riesgos es lo que garantiza que sea segura y sostenible.

23

8. Ejemplo de Aplicación

Implementación de KRIs en una Entidad Pública

Objetivo

Reducir ciberataques dirigidos a funcionarios

KRIs definidos

Indicador	Meta
Equipos sin parchear	<5%
Incidentes de phishing	<3 mensuales
Vulnerabilidades críticas abiertas	<10
Usuarios con MFA habilitado	>95%
Tiempo de respuesta a incidentes	<4 horas

Resultados esperados

- Mayor visibilidad del riesgo.
- Detección temprana.
- Mejor toma de decisiones.



24

01

Caso de Discusión


 Freddy Alvarado Vargas
falvarado@esan.edu.pe


25

Estructura del Trabajo Final Grupal

Aplicación de Gestión de Riesgos de Ciberseguridad



1. Antecedentes de la organización
2. Identificación de activos de información
3. Identificación de amenazas y vulnerabilidades.
4. Elaboración de una Matriz de Riesgos
5. Desarrollo de Indicadores de riesgos KRIs
6. Propuestas de controles según marcos de referencia.
7. Conclusiones y Recomendaciones.
8. Bibliografía.

Informe en Word**Fecha de Presentación: 24 de junio**
 Freddy Alvarado Vargas
falvarado@esan.edu.pe


26

Caso: Incidente de Seguridad en Uber (2022)



Contexto del caso

En septiembre de 2022, Uber fue víctima de un incidente de seguridad ampliamente difundido a nivel mundial. El ataque no se produjo mediante una vulnerabilidad técnica compleja, sino a través de una combinación de ingeniería social, gestión inadecuada de identidades y deficiencias en el monitoreo continuo....



Trabajo a realizar

- Lea y discuta con sus compañeros el caso ubicado en el Esan Virtual.
- Responda las cinco preguntas del caso.
- Presente sus respuestas en un Power Point.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



27

Caso: Incidente de Seguridad en Uber (2022)

Preguntas para discusión

1. Desde la perspectiva del monitoreo continuo, ¿qué señales tempranas debieron haber alertado a la organización antes de que el atacante obtuviera acceso?
2. Analizando el ciclo de gestión de incidentes (Preparación, Detección, Contención, Erradicación, Recuperación y Lecciones Aprendidas), ¿en qué fases identifica mayores debilidades y por qué?
3. Si usted fuera responsable de seguridad (CISO), ¿qué acciones inmediatas y qué acciones de largo plazo implementaría para reducir la probabilidad de un incidente similar?
4. Diseñe al menos cinco KRIs que permitan monitorear el riesgo asociado a robo de credenciales, abuso de MFA y accesos privilegiados.
Indique:
 - Indicador.
 - Fórmula o métrica.
 - Umbral de alerta.
 - Acción correctiva.
5. Relacionando el caso con ISO 27001, ISO 31000, NIST CSF 2.0 y NIST SP 800-53, ¿qué controles o prácticas de gestión de riesgos hubieran reducido significativamente la probabilidad o el impacto del incidente?



Freddy Alvarado Vargas
falvarado@esan.edu.pe



28

Caso: Incidente de Seguridad en Uber (2022)

Respuestas Ideales



Pregunta	Respuesta ideal
¿Qué señales tempranas debieron detectarse?	- Múltiples rechazos MFA, - accesos desde ubicaciones inusuales, - comportamiento anómalo del usuario, - intentos repetitivos de autenticación y - alertas no investigadas oportunamente.
¿Qué debilidades existieron en la gestión del incidente?	- Deficiencias en preparación, monitoreo, - gestión de identidades, - revisión de privilegios y - seguimiento de hallazgos de auditoría.
¿Qué acciones debieron implementarse?	- MFA resistente al phishing, - Zero Trust, - PAM, - monitoreo continuo, - capacitación, - segmentación de accesos y - fortalecimiento del SOC.
¿Qué KRIs hubieran ayudado?	- Número de rechazos MFA por usuario, - accesos desde ubicaciones anómalas, - cuentas privilegiadas sin revisión, - tiempo de atención de alertas críticas y - porcentaje de alertas investigadas.
¿Qué controles faltaron?	- Gestión de identidades y accesos (IAM), - gestión de accesos privilegiados (PAM), - monitoreo continuo, - autenticación adaptativa, - auditorías periódicas, - gestión de terceros y - mejora continua basada en riesgos.

Freddy Alvarado Vargas
falvarado@esan.edu.pe



29

Conclusiones de la sesión

1. La **gestión de riesgos es un proceso continuo**. Identificar, analizar y tratar riesgos no es suficiente; las organizaciones deben monitorearlos constantemente para asegurar que los controles sigan siendo efectivos frente a nuevas amenazas.
2. Los **KRIs y el monitoreo ayudan a detectar problemas antes de que ocurran incidentes**. Los indicadores permiten identificar señales de alerta temprana y tomar acciones oportunas para reducir la exposición al riesgo.
3. La **auditoría y la gestión de incidentes fortalecen la seguridad organizacional**. Las auditorías ayudan a encontrar debilidades en los controles, mientras que una adecuada respuesta a incidentes reduce sus impactos y facilita la recuperación.
4. La **mejora continua permite adaptar la seguridad a un entorno cambiante**. A través del ciclo PDCA, las organizaciones pueden aprender de sus experiencias, corregir errores y fortalecer continuamente sus procesos de ciberseguridad.
5. La **transformación digital genera nuevos riesgos que deben gestionarse de forma proactiva**. Tecnologías como la nube, la inteligencia artificial y el IoT ofrecen grandes beneficios, pero también introducen amenazas que requieren monitoreo y controles adecuados.



Freddy Alvarado Vargas
falvarado@esan.edu.pe



30



"La gestión de riesgos de ciberseguridad no termina con la implementación de controles. Su verdadero valor está en la capacidad de la organización para monitorear, aprender y mejorar continuamente, fortaleciendo su resiliencia frente a un entorno digital en constante evolución."



Freddy Alvarado Vargas
falvarado@esan.edu.pe



31



*Y nunca olvidar nuestra
responsabilidad con el
planeta...*

Muchas gracias!!

Freddy Alvarado Vargas

Profesor Área Operaciones y TI
falvarado@esan.edu.pe

32